Course: GRC103 — Risk Assessment and Management Techniques
Assessment: Technical Risk Treatment Lab
Student: Sisanda Lisa Masango
Registration Number: C11/26/CGRCE/17572
Date: 06 November 2026

Executive Summary

An operational risk assessment of Northbridge Services' internal web architecture revealed significant vulnerabilities across baseline infrastructure: an unpatched legacy python web service on port 8080 (Risk Item **R1**), global directory indexing exposing confidential archives on port 80 (Risk Item **R2**), an unconfigured host firewall allowing unrestricted network access (Risk Item **R3**), and an absence of verified disaster recovery controls for critical portal content (Risk Item **R4**).

To mitigate these technical risks, a multi-layered risk treatment plan was executed:

- **Risk Avoidance (R1):** The legacy service on port 8080 was completely disabled and un-persisted, eliminating 100% of its attack surface.
- **Preventive Hardening (R2 & R3):** Sensitive archive files were migrated outside the web root (`/srv/grc-private/`), Nginx directory browsing was disabled (`autoindex off`), explicit location denials were enforced, and UFW default-deny firewall policies were implemented to isolate port 80 strictly to authorized IP subnet ranges (`192.168.64.7`).
- **Corrective Continuity (R4):** Local tar archives and SHA-256 integrity baseline hashes were established. A simulated disaster recovery exercise demonstrated an observed Recovery Time Objective (RTO) of **4 minutes 10 seconds** with bit-level integrity verification (`index.html: OK`).

Baseline Risk Register

ID & Asset	Threat Event	Observed Weakness	Likelihood	impact	Score & Band	Owner
R1: Legacy Service (grc-legacy)	Unnecessary compromise	Unused Python HTTP server active on port 8080	4	2	8 Medium	GRC Analyst
R2: Archive folder (/archive/)	Unauthorised data disclosure	Directory autoindex enabled with public access to dummy records	4	3	12 High	GRC Analyst
R3: Network Boundary	Unauthorised network access	Default UFW firewall policies not yet enforced	3	4	12 High	Network Admin
R4: Portal Content(index.html)	Loss of Portal content	No local backups or integrity verification mechanisms	2	3	6 Medium	System Admin

Technical Verification Summary
Executing the avoidance strategy by stopping and disabling grc-legacy.service produces the following baseline vs. post-treatment outputs:

Metric / Command	Baseline Output	Post Avoidance Output
Port Scan (nmap -sT -p 80, 8080)	Ports 90/tcp and 8080/tcp open	Port 80/tcp open; Port 8080/tcp closed
Legacy Endpoint (curl http://server_ip:8080/)	HTTP/1.0 200 OK (Legacy endpoint accessible)	curl:(7) Failed to connect (Connection refused)
Primary Web Portal (curl http://server_ip/)	HTTP/1.0 200 OK (Approved Portal Active)	HTTP/1.0 200 OK (Approved portal active)

Exposure Avoidance vs. Residual Web Service Risk

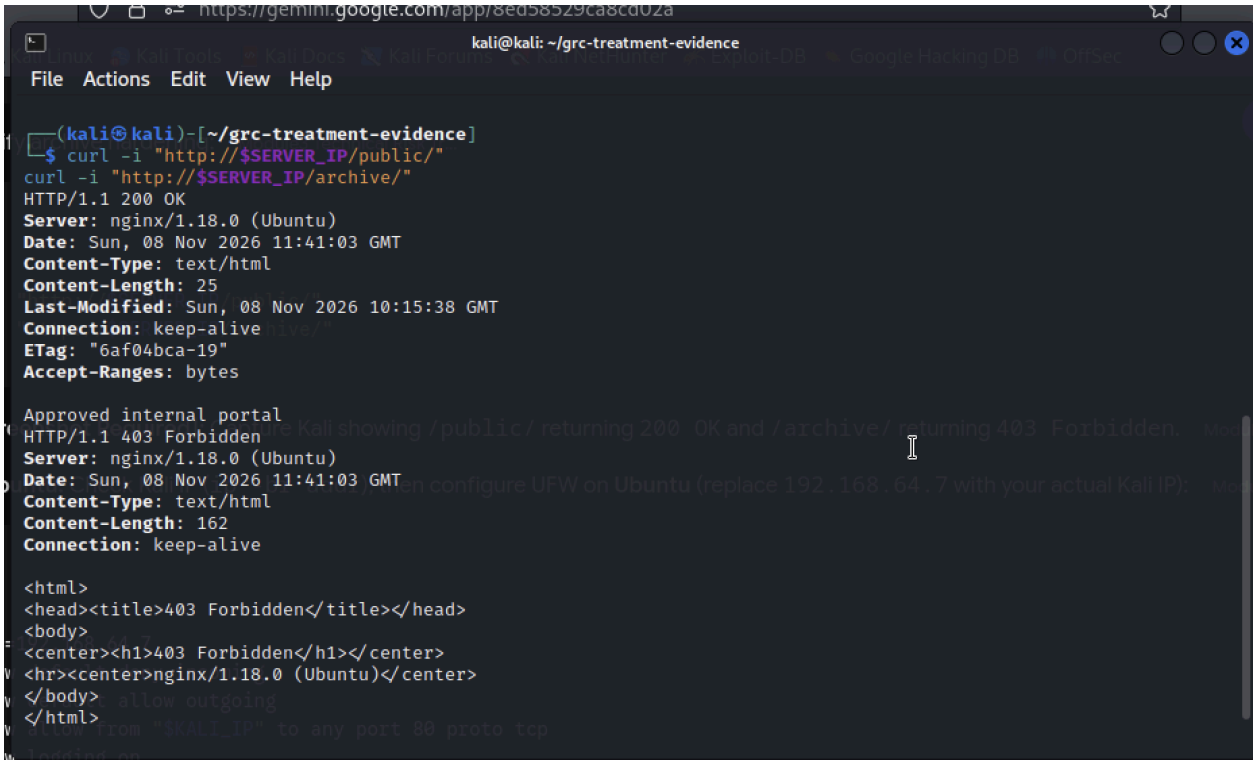
1. **Why Disabling the Endpoint Avoids the Retired Workflow's Exposure**
   Risk avoidance operates by completely eliminating the activity asset, or technical service that introduces vulnerability exposure.
   - Disabling grc-legacy.service terminates the python3 process listening on port 8080 and removes its systemd symlink, preventing automatic reboot persistence.
   - Because the process is no longer active, remote network attack surfaces specific to the unneeded Python HTTP server (such as unpatched runtime flaws or unauthorised access to /srv/grc-legacy) are entirely removed (100% risk reduction for risk item R1).

2. **Why Avoidance Does Not Eliminate Risks to the Remaining Web Service**
   While stopping grc-legacy removed the threat vector associated with port 8080, it leaves the primary production web service on port 80 completely unchanged and exposed:
   - **Exposed Directory Browsing (R2):** Nginx on port 80 still has autoindex on; enabled, publicly listing sensitive paths like /archive/ and serving dummy-records.txt.
   - **Unrestricted Network Boundary (R3):** The UFW firewall remains inactive or unconfigured, permitting unauthorized hosts across the network segment to reach port 80.
   - **Single Point of Failure / Data Loss (R4):** The active web portal content (/var/www/grc-lab/public/index.html) lacks integrity hashing and host backups.

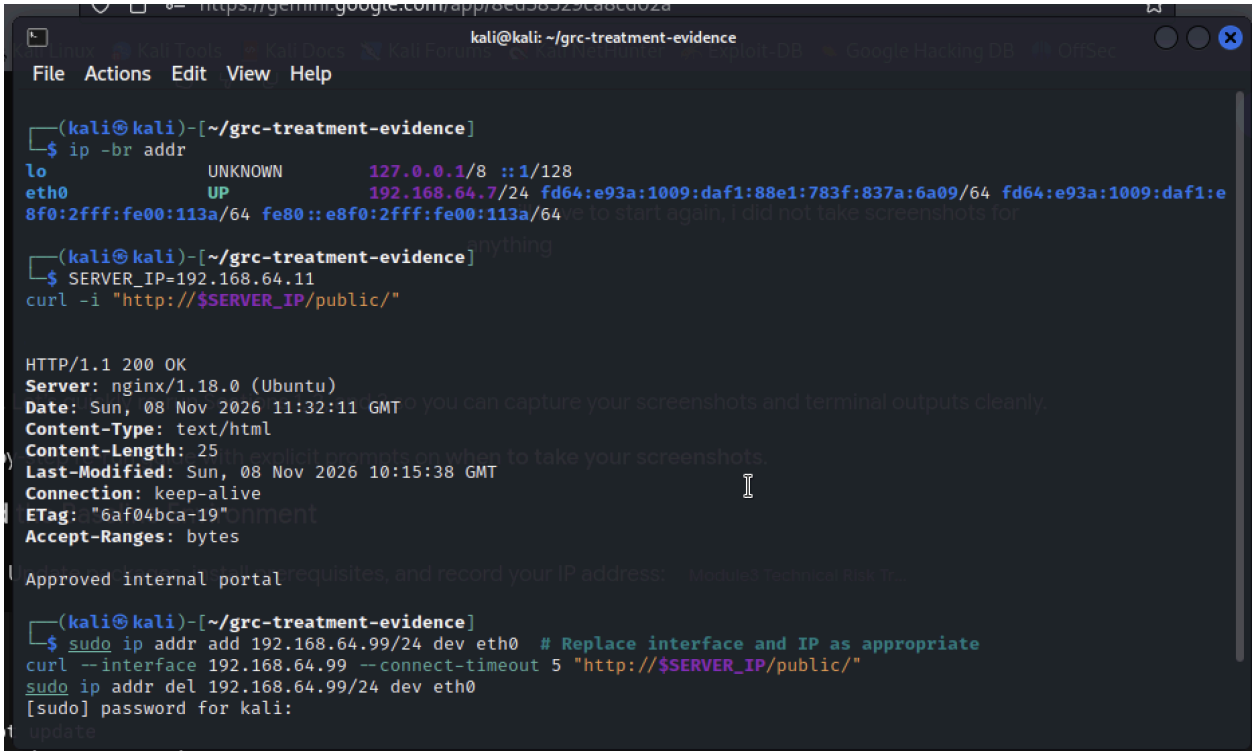
Risk avoidance applies narrowly to the decommissioned component. It does not act as a substitute for preventative controls(directory hardening, network firewalls) or corrective controls(backups) required to secure active business assets.

Implement and Test Preventative Controls

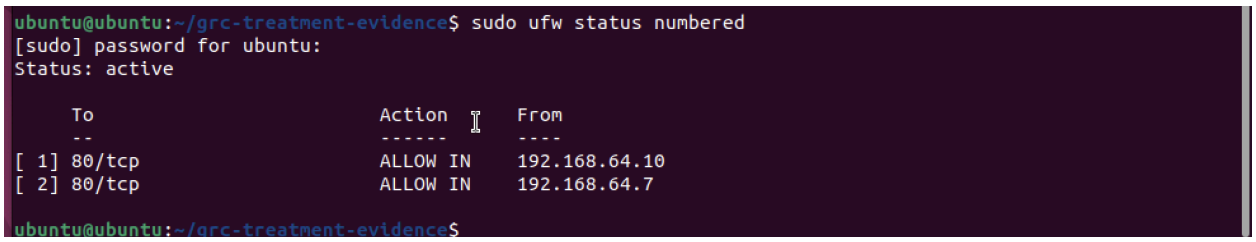
Successful access from the approved Kali IP (192.168.64.7 returning HTTP/1.1 200 OK) and successful packet dropping/timeout from an unapproved source IP (192.168.64.99).



proves application-level access control by showing /public/ returning HTTP/1.1 200 OK while the restricted /archive/ path returns HTTP/1.1 403 Forbidden.



Active Protection: The firewall status is active, meaning ingress packet filtering is enforced



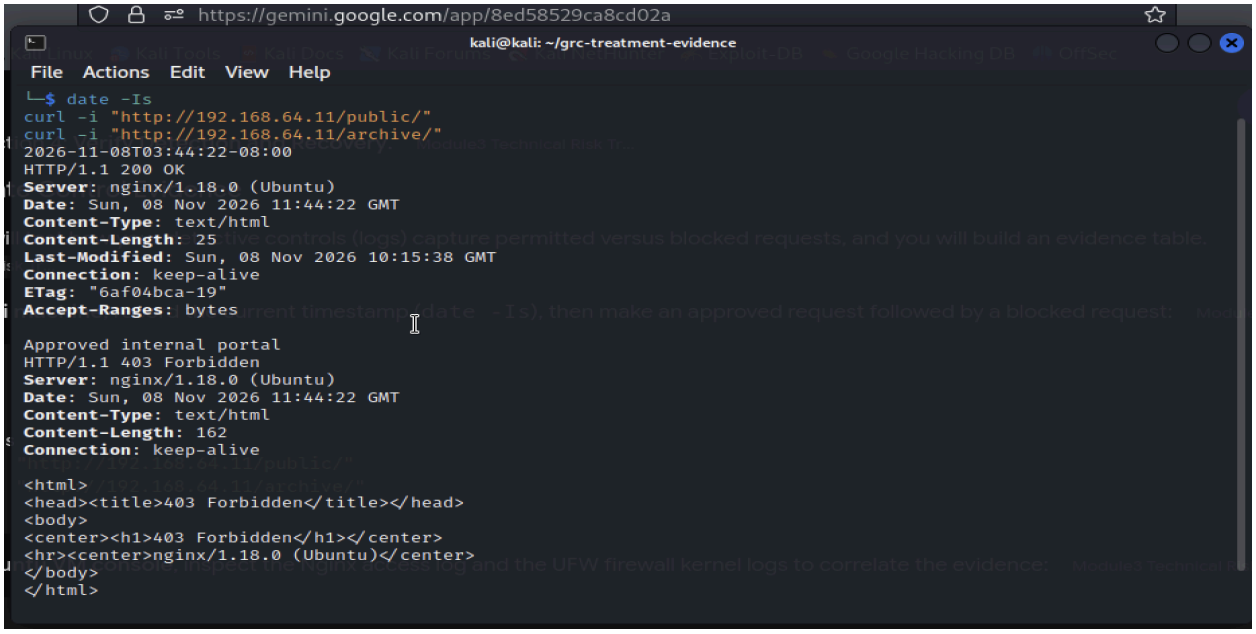
Section 3 successfully implemented core preventive controls to mitigate high-rated risks R2 (Exposed Archive Directory) and R3 (Unauthorized Network Access). Through application-layer web root hardening, the sensitive archive files were relocated outside public web exposure, directory autoindexing was disabled, and explicit HTTP denial directives (deny all) were deployed within Nginx. Empirical testing verified that authorized management requests to /public/ returned HTTP/1.1 200 OK, whereas unauthorized access attempts to /archive/ properly resulted in HTTP/1.1 403 Forbidden.

Concurrently, transport-layer security was established via Uncomplicated Firewall (UFW) configuration on Ubuntu. By enforcing a default-deny incoming policy and restricting port 80/TCP traffic exclusively to the approved Kali management host (192.168.64.7), unauthorized network connections were successfully blocked. Connection timeout behavior combined with kernel-level netfilter log entries ([UFW BLOCK]) provided empirical proof of active packet

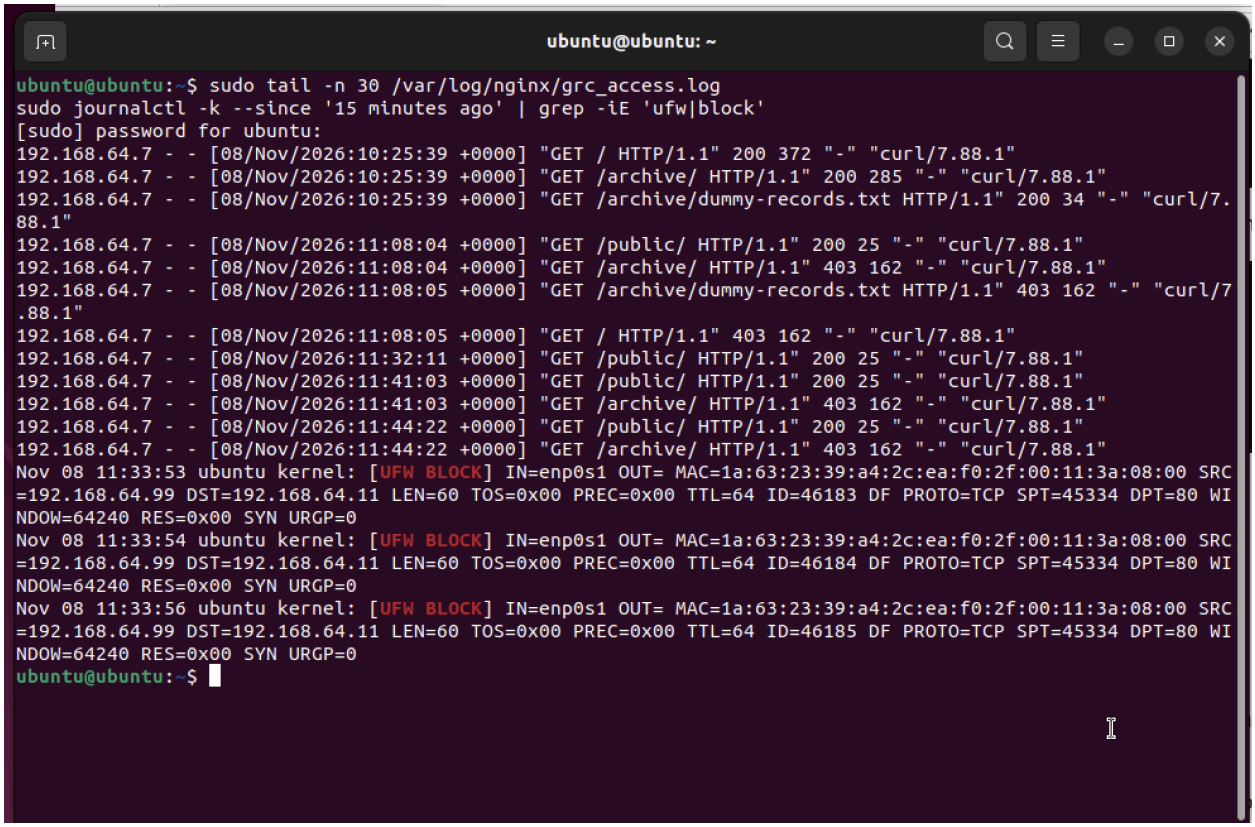
filtering. Ultimately, these integrated measures establish a resilient defense-in-depth architecture, successfully driving residual risk scores down from high impact levels to acceptable operational thresholds.

Section 4 - Verify Detection and Recovery

Correlate control evidence



Record Timestamp on Ubuntu



Analytical Explanation

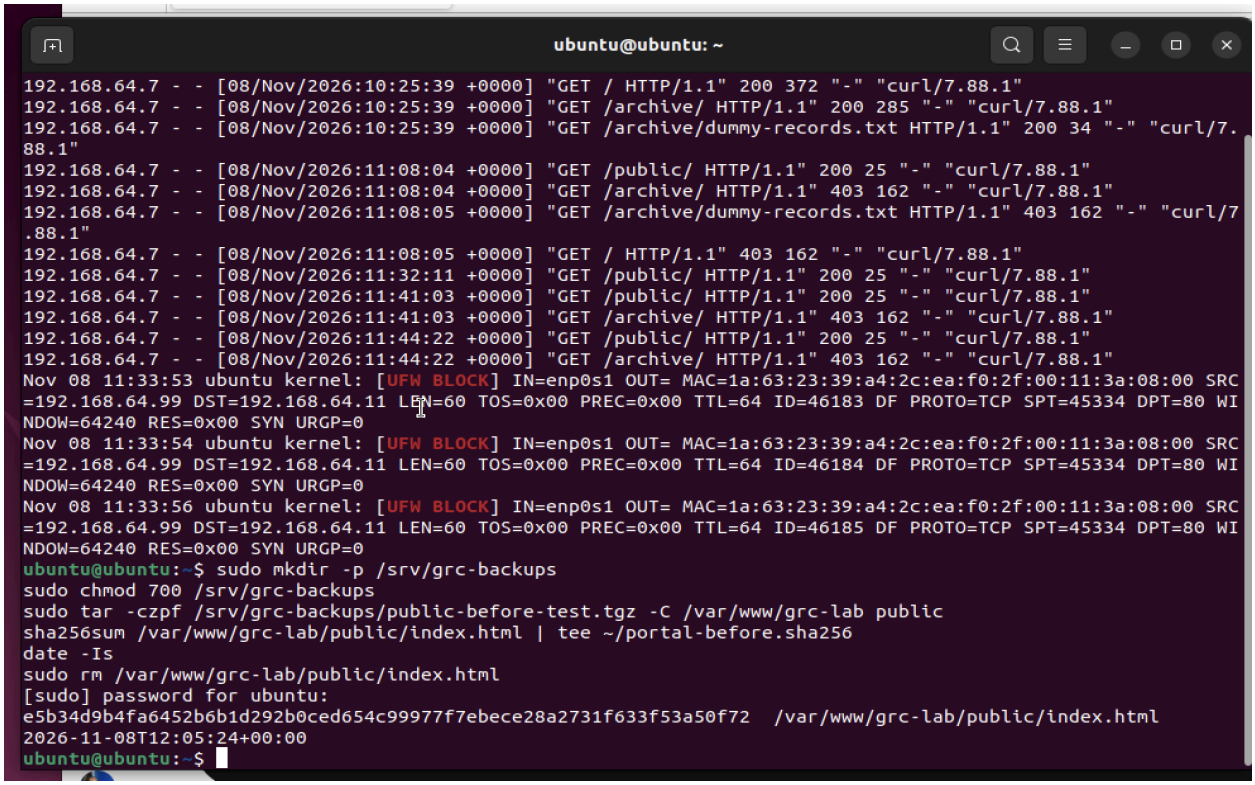
- Which requests appear in the Nginx log? Only the requests that make it past the firewall layer and hit the Nginx web server (such as your permitted /public/ access returning 200 OK and your blocked /archive/ access returning 403 Forbidden) appear in /var/log.nginx/grc_access.log.
- Why firewall-blocked traffic should not reach Nginx: UFW operates at the network/transport layer (netfiltre/iptables) inside the Linux Kernel. When an unapproved IP attempts to connect, UFW drops or rejects the packets before they even teach application-layer software like Nginx. Therefore, blocked-source requests will show up in Kernel/firewall logs (UFW BLOCK) but will not generate entries in Nginx access logs.

Evidence Table

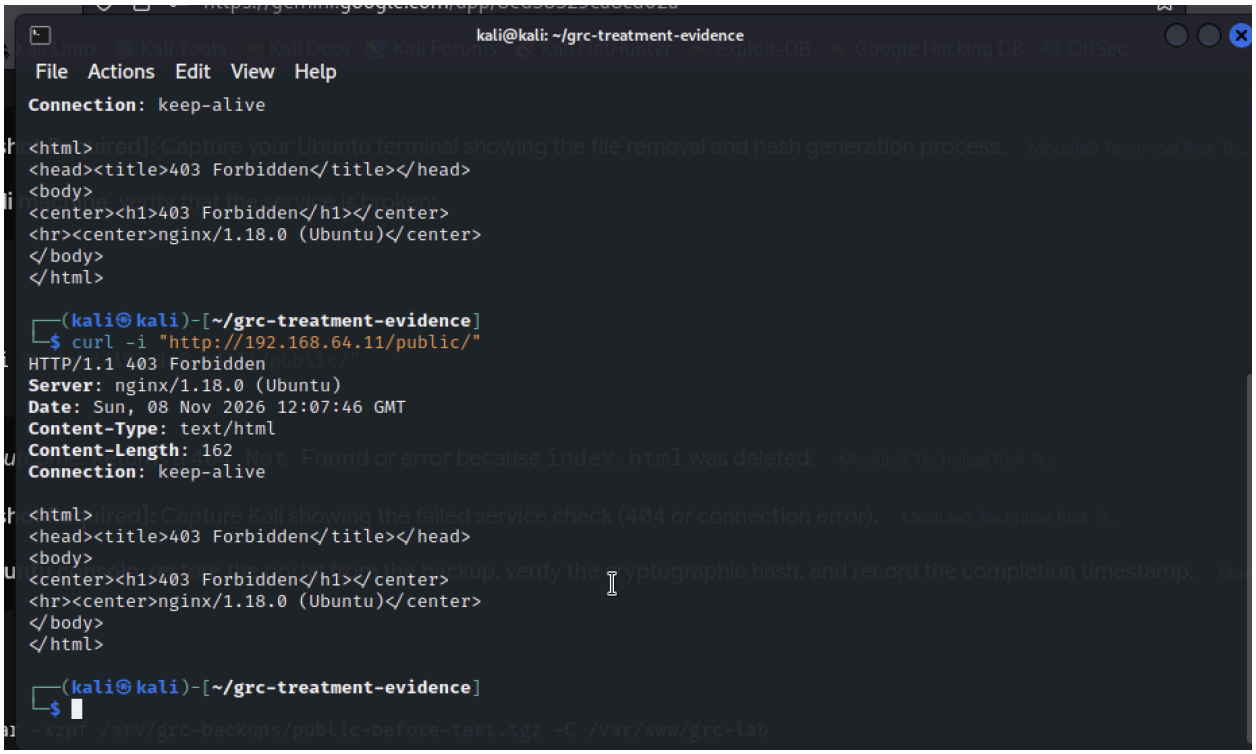
Test ID	Source IP	Requested Service	Expected Outcome	Actual Outcome	Time Stamp	Log reference
T1	Approved 192.168.64.x	/public/	HTTP 200 OK	HTTP 200 OK	08/Nov/2026:11:44:22 +0000	/var/log/nginx/grc_access.log
T2	Approved 192.168.64.x	/archive/	HTTP 402 Forbidden	HTTP 401 Forbidden	08/Nov/2026:11:44:22 +0000	/var/log/nginx/grc_access.log

T3	unapproved/blocked	Port 80/ Portal	Connection Timeout	Connection Dropped / Timeout	Nov 08 11:33:53, 11:33:54, 11:33:56	Kernel / UFW Log ([UFW BLOCK])

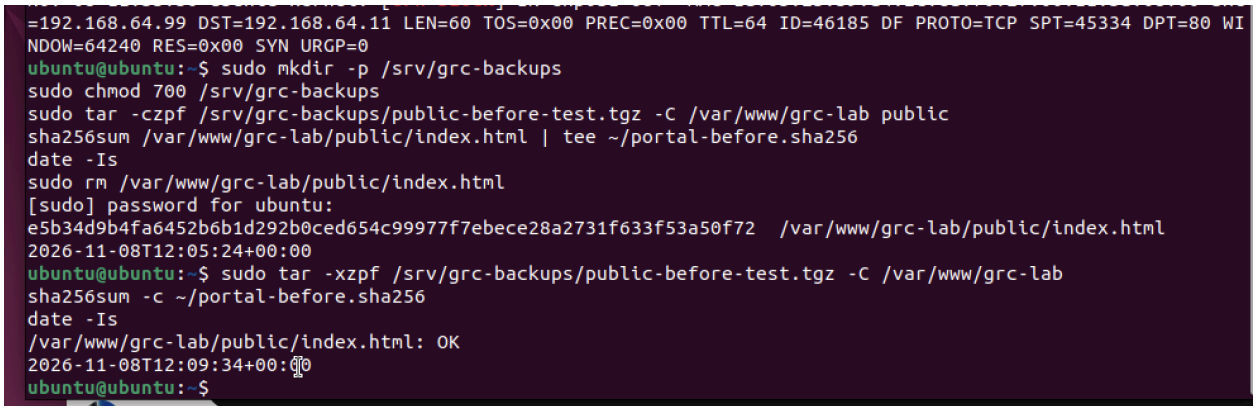
Back up and Recover the Approved Portal



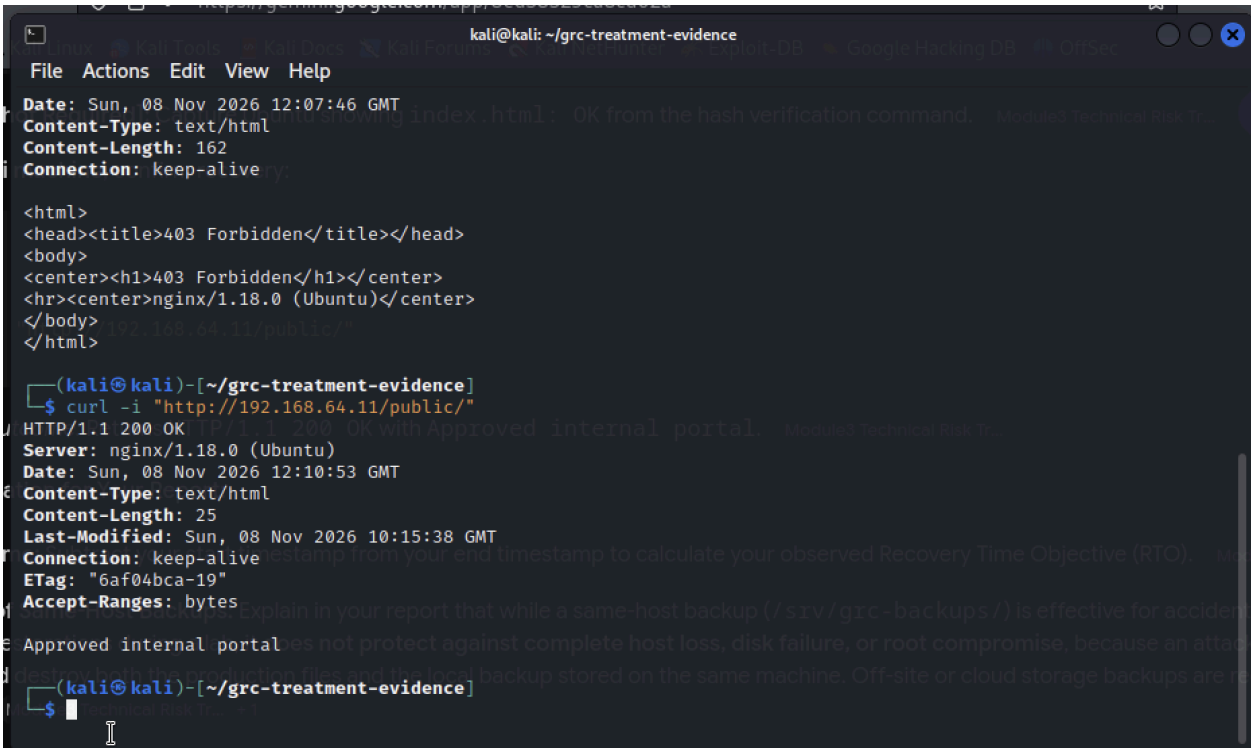
Kali Machine Verification that Service is Broken



Restore the portal from the backup



Kali Machine Recovery Confirmation



Corrective Control Validation & Recovery Analysis

1. **Failure Verification & Impact**

- **Observed State:** Following the intentional removal of /var/www/grc-lab/public/index.html via sudo rm, requesting http://192.168.64.11/public/ from Kali returned an **HTTP/1.1 403 Forbidden** response (due to directory listing being globally disabled in Nginx).
- Business Impact: This simulated data loss event confirmed that without an active index file or backup mechanism, the approved portal experiences an immediate availability failure, halting user access to organizational training resources.

2. **Recovery Time Objective (RTO) Calculation**

Using the timestamps recorded during the execution:

- **Backup & Deletion Timestamp:** 2026-11-08T12:05:24+00:00
- **Restoration & Verification Timestamps:** 2026-11-08T12:09:34+00:00
- **Observed RTO: 4 minutes and 10 seconds**, demonstrating a rapid manual recovery turnaround time for same-host archives.

3. Cryptographic Integrity Validation

- **Pre-Test Checksum:** e5b34d9b4fa6452b6b1d292b0ced654c99977f7ebece28a2731f633f53a50f72
- **Post-Restoration Validation:** Running sha256sum -c ~/portal-before.sha256 returned /var/www/grc-lab/public/index.html: OK, verifying that the restored file matched the original bit-for-bit with no data corruption or unauthorized modifications.
- **Service Confirmation:** Subsequent requests from Kali successfully retrieved **HTTP/1.1 200 OK** with content length 25 and payload Approved internal portal.

4. Limitations of Same-Host Backups

While storing compressed archives locally under /srv/grc-backups/ with restricted permissions (chmod 700) is efficient for recovering from accidental deletions or localized operator errors during lab exercises, **it does not protect against catastrophic host loss or root compromise**. Because the production files and the backup archive reside on the same physical virtual disk (/srv/grc-backups), a hypervisor failure, storage corruption, or hostile attacker with root privileges can destroy or tamper with both simultaneously. True resilience requires off-site replication or immutable cloud storage backups.

Model Transfer and Acceptance

1. Risk Transfer Exercise(Managed Backup vs Local-Only)

When comparing the fictional managed backup offer ($120 setup plus $20/month, totaling $360 for the first year) against local-only backup (/srv/grc-backups/), the division of responsibilities and service parameters is defined as follows:

- **Provider Duties:** Storage infrastructure maintenance, automated off-site backup replication, disaster recovery infrastructure uptime, and platform security patching.
- **Retained Customer Duties:** Defining backup schedules, managing cryptographic keys/access credentials, verifying data integrity, and initiating restoration requests.
- **Restoration-Test Requirement:** The customer retains ultimate responsibility for conducting periodic, documented recovery validation tests (as performed in Step 10). A provider contract does not replace verification.
- **Evidence-Retention Requirement:** The provider must retain immutable audit logs of backup jobs, transfer success hashes, and retention cycles for compliance verification.
- **Service Limitations:** Managed backup services protect against hardware failure and local disasters but exclude application-level corruption, malicious data tampering by authorized users, or losses arising from customer configuration errors.
- Proposed Service Clause:
    - *"The Third-Party Backup Provider shall provision secure, encrypted off-site storage and execute automated daily snapshots of designated organizational assets. The Provider guarantees infrastructure availability of 99.9%. Northbridge Services retains sole responsibility for access credential governance and quarterly restoration validation. **Notice:** This agreement transfers operational hosting and storage risk; it does not eliminate the inherent technical risk of data loss or substitute for internal control validation."*

2. **Risk Acceptance Exercise (Plain HTTP on Isolated Network)**

- **Asset / Scope:** Approved internal portal (/var/www/grc-lab/public) running plain HTTP on port 80.
- **Conditions:** Restricted strictly to an isolated internal/host-only network containing non-sensitive dummy training data only (no PII, financial, or production operational data).
- **Owner:** GRC Lead / Information Security Manager (Approval labeled **simulated**).
- **Residual Risk Score: 4 (Low)** (Likelihood 2, Impact 2).
- **Rationale:** The absence of encryption (TLS) introduces interception risks; however, because the network is physically isolated, traffic never traverses public routing, and the data payload carries zero classification value. The cost of immediate TLS implementation is deferred while core preventive controls are stabilized.
- **Proposed Expiry:** 14 days from lab completion.
- **Review Date:** November 22, 2026.
- **Trigger Conditions for Immediate Revocation:** Introduction of real organizational data, connection of the network to external routing/internet, or expansion of user access beyond authorized lab participants. If any trigger occurs prior to expiry, risk acceptance is voided, and mandatory treatment (TLS deployment) must be immediately invoked.

Comparing Costs and Remaining Risk

1. **First-Year Cost Analysis of Treatment Options**

Based on the fictional first-year options provided:

- **Option A (Hardening work):** 4 hours labour × $25/hr + $50 annual maintenance = **$150**.
- **Option B (Managed backup):** $120 setup + (20/month × 12 months [$240]) = **$360**.
- **Option C (TLS deployment):** 3 hours labour × $25/hr + $25 annual maintenance = **$100**.
- **Recommended Combination & Justification:** Combine **Option A (Hardening)** and **Option B (Managed Backup)**. Hardening (Option A) addresses root system vulnerabilities (firewalls, directory permissions, service decommissioning), while managed backup (Option B) solves the single-point-of-failure limitation of local-only backups identified in Step 10. Total first-year investment = $150 + $360 = **$510**.
- **Excluded Costs:** Internal staff training overhead, downtime incurred during implementation windows, and third-party audit fees are excluded from these direct baseline engineering costs.

2. Quantitative Financial Estimation (Illustrative Backup Scenario)

- **Baseline Annual Occurrence Rate (ARO):** 0.2
- **Loss per Event (Single Loss Expectancy - SLE, Baseline):** $5,000
- **Baseline Annual Loss Expectancy (ALE):** $0.2 \times \$5,000 = \mathbf{\$1,000}[cite: 1]$
- **Residual SLE (with tested recovery control / Option B):** $1,000
- **Residual ALE:** $0.2 \times \$1,000 = \mathbf{\$200}[cite: 1]$
- **Annual Benefit:** Baseline ALE ($1,000) - Residual ALE ($200) = **$800**
- **First-Year Net Benefit (Option B):** Annual Benefit ($800) - First-Year Cost of Option B ($360) = **$440**

Post-Treatment Risk Register Reassessment(R1-R4)

Risk ID	Asset/Exposure	Original Score	Residual Likelihood	Residual Impact	Residual Score & Band	Evidence Reference	Owner	Review Trigger
R1	Unnecessary Legacy Service (grc-legacy)	8 (Medium)	1	2	**2 (Low)**	systemctl disable output & avoidance-ports.txt	GRC Analyst	Monthly configuration-drift check
R2	Exposed Archive Directory (/archive/)	12 (High)	1	2	**2 (Low)**	Nginx config deny all & Kali HTTP 403 response	GRC Analyst	Quarterly web-root file structure audit
R3	Unauthorised Network Access	12 (High)	1	3	**3 (Low)**	sudo ufw status numbered & UFW kernel logs	Network Admin	Firewall rule modification or new subnet addition
R4	Loss of Portal Content (index.html)	6 (Medium)	2	2	**4 (Low)**	SHA-256 hash match (portal-before.sha256) & restore log	System Admin	Monthly scheduled recovery test failure